

Reporte ejecutivo

Gestión de riesgos de seguridad - Clínica privada

Objetivo. Resumir para el directorio los riesgos más importantes que encontré al analizar el escenario de la clínica con SimpleRisk y mostrar qué conviene atender primero.

La clínica tiene 120 empleados y atiende aproximadamente a 800 pacientes por día. Para este trabajo tomé como principales activos las historias clínicas digitales, los datos de obras sociales y la información de facturación. Además, se parte de una auditoría externa que detectó debilidades de seguridad.

1. Resumen ejecutivo

El riesgo que considero más importante es la indisponibilidad de la información por fallas en las copias de respaldo (ID 1008). En SimpleRisk quedó con un riesgo inherente de 8 (High). También quedaron como temas importantes la continuidad del sistema de historias clínicas y el control de los accesos a la información.

A partir de las mitigaciones cargadas, algunos riesgos bajan en su nivel residual. De todos modos, esto debería comprobarse en la práctica, especialmente en respaldos y recuperación. Mi prioridad sería asegurar que la clínica pueda recuperar la información antes de concentrarse en mejoras menos urgentes.

2. Top 5 de riesgos

ID	Riesgo	Inherente	Residual
1008	Fallas en las copias de respaldo	8 - High	4 - Medium
1005	Interrupción del sistema de historias clínicas	6.4 - Medium	3.2 - Low
1007	Acceso de personal que ya no debería tener permisos	6.4 - Medium	6.4 - Medium
1003	Modificación incorrecta de una historia clínica	6 - Medium	3 - Low
1004	Exposición de información de pacientes mediante exportaciones	4.8 - Medium	4.8 - Medium

Los riesgos 1002 y 1006 también quedaron en nivel Medium (4.8), por lo que siguen formando parte del trabajo pendiente, aunque no entran en este Top 5.

3. Planes de acción

Los tres planes siguientes están asociados al riesgo 1008, que es el único que quedó en nivel High en la evaluación inherente. Las fechas y los presupuestos son estimaciones realizadas para este trabajo práctico, no datos reales de la clínica.

Plan	Vencimiento	Responsable	Presupuesto	Estado
Verificar las copias de respaldo	30/09/2026	Analista de Riesgos Demo	USD 300	No iniciado
Realizar una prueba de recuperación	15/10/2026	Analista de Riesgos Demo	USD 500	No iniciado
Mejorar el esquema de respaldo	31/10/2026	Analista de Riesgos Demo	USD 700	No iniciado

En SimpleRisk se cargaron las mitigaciones correspondientes. Estos tres puntos se presentan como planes de trabajo para ordenar el tratamiento y seguimiento del riesgo 1008; no se presentan como tres objetos independientes creados en la herramienta.

4. Recomendaciones prioritarias

- Respallos: comprobar que las copias se hagan correctamente y realizar una restauración de prueba. Tener un backup no alcanza si nunca se verificó que puede recuperarse.
- Accesos: revisar altas, bajas y cambios de permisos para evitar que una persona conserve acceso a historias clínicas cuando ya no corresponde.
- Historias clínicas: limitar exportaciones y mantener controles para poder detectar cambios incorrectos o no autorizados.
- Infraestructura: los centros de datos no deberían ubicarse al lado de cocinas ni debajo de piletas, para reducir riesgos de incendio e inundación.

5. Una idea simple para pensar la seguridad

Para explicar una amenaza externa de forma sencilla, se puede usar el ejemplo del lobo feroz y Caperucita Roja: la clínica debe asumir que alguien puede intentar encontrar una debilidad. Y la idea de los 3 cerditos sirve para recordar que no conviene depender de una sola defensa, sino de varias capas: accesos, respaldos, monitoreo y recuperación.

6. Análisis de los riesgos y tratamiento

ID	Riesgo	Nivel	Tratamiento / estado
1002	Uso indebido de cuentas con acceso a historias clínicas	4.8 - Medium	Mitigation Planned
1003	Modificación incorrecta de una historia clínica	6 → 3	Mitigation + Mgmt Reviewed
1004	Exposición de información de pacientes mediante exportaciones	4.8 - Medium	Mitigation Planned
1005	Interrupción del sistema de historias clínicas durante la atención	6.4 → 3.2	Mitigation Planned
1006	Error en la facturación de prestaciones a obras sociales	4.8 - Medium	Sin mitigación registrada
1007	Acceso de personal que ya no debería tener permisos	6.4 - Medium	Mitigation Planned
1008	Indisponibilidad de información por fallas en las copias de respaldo	8 → 4	Mitigation Planned + Accepted

La evaluación usa la escala que muestra SimpleRisk. En los casos con flecha se indica el cambio desde el riesgo inherente al residual después de la mitigación.

7. Comparación con NIST SP 800-30

SimpleRisk me resultó útil para registrar riesgos, asignar probabilidad e impacto y hacer un seguimiento de las mitigaciones. La ventaja es que permite ver rápidamente qué riesgos necesitan más atención. La desventaja es que la matriz termina simplificando un análisis que, en una organización real, puede necesitar más contexto.

NIST SP 800-30 Rev. 1 propone un proceso más amplio para evaluar riesgos: preparar la evaluación, realizarla y mantenerla. Su principal ventaja es que permite analizar el riesgo con mayor detalle y contexto. Como desventaja, requiere más trabajo y documentación que el enfoque simple utilizado en este trabajo. [1]

8. Integración propuesta con Jira

Una posible mejora sería conectar SimpleRisk con Jira para convertir las acciones de mitigación en tareas de seguimiento. Por ejemplo, cuando un riesgo pase a una etapa que requiera trabajo, se podría crear una incidencia con el ID del riesgo, responsable, vencimiento y estado. Jira cuenta con API REST y mecanismos de webhook para trabajar con eventos de sus incidencias. [2][3]

En este trabajo esta integración queda planteada como propuesta y no como una integración implementada. La idea sería usar un pequeño servicio intermedio entre SimpleRisk y Jira y mantener las credenciales fuera del repositorio.

9. Conclusión

La prioridad es asegurar la recuperación de la información de la clínica ante una falla. Después de eso, considero importante reforzar el control de accesos y la protección de las historias clínicas. El trabajo con SimpleRisk permitió ordenar los riesgos y ver dónde las mitigaciones reducen el riesgo residual. El siguiente paso, fuera de este trabajo práctico, sería comprobar que los controles realmente funcionan y mantener la evaluación actualizada.

Fuentes

[1] NIST. Guide for Conducting Risk Assessments, SP 800-30 Rev. 1. Sitio oficial: <https://www.nist.gov/publications/guide-conducting-risk-assessments>

[2] Atlassian Developer. Jira Cloud platform REST API - Webhooks. Sitio oficial: <https://developer.atlassian.com/cloud/jira/platform/rest/v3/api-group-webhooks/>

[3] Atlassian Developer. Webhooks. Sitio oficial: <https://developer.atlassian.com/cloud/jira/platform/webhooks/>